

Manual 14 - Implementação Controlada PCI DSS v4.0.1

Authority boundary: practical implementation guidance based on the current PCI SSC source state. This is not PCI SSC endorsement, certification, an official translation, legal advice, or a substitute for required qualified validation.

Manual 14 — PCI DSS Implementation Paths

Essential path

For smaller or lower-complexity environments that still require disciplined PCI DSS scoping and evidence. Minimum outputs: CDE scope statement, data-flow diagram, asset inventory, responsibility matrix, core configuration standards, access/MFA evidence, vulnerability evidence, logging evidence, incident-response evidence, third-party attestations, and remediation register.

Structured path

For organizations with multiple applications, service providers, business units, or formal compliance operations. Adds control ownership, evidence calendars, change-driven reassessment, service-provider dependency mapping, secure-development evidence, penetration-test governance, exception/compensating-control records, and management reporting.

Enhanced path

For complex enterprises, high transaction volumes, hybrid/multi-cloud environments, extensive third-party dependencies, or environments requiring continuous assurance. Adds automated evidence collection where appropriate, continuous control monitoring, risk-based sampling, dependency graphing, control-health metrics, integrated GRC workflows, and formal management assurance.

Evidence object schema

Every control implementation should record:

- requirement/control objective
- applicability and scope
- accountable owner

- responsible operator
- implementation procedure
- operating frequency
- evidence artifact
- evidence repository/location
- retention expectation
- reviewer/test procedure
- result/status
- exception or compensating-control reference
- remediation owner/date
- reassessment trigger

Decision controls

The controlled manual must explicitly separate:

- defined approach vs customized approach where applicable;
- underlying security requirements vs SAQ/ROC/AOC validation instruments;
- PCI DSS requirements vs adjacent PCI standards;
- PCI DSS obligations vs contractual/acquirer/payment-brand requirements;
- PCI DSS requirements vs jurisdiction-specific law;
- technical remediation vs formal exception/compensating-control governance.

Publication rule

Implementation-path maturity must never be represented as certification status. Publication requires exact-candidate QA, durable artifacts, provenance, release-registry reconciliation, and sequential predecessor clearance.

Manual 14 — Implementação Controlada PCI DSS v4.0.1

Chapter 01 — Governança e modelo operacional PCI DSS

Estabeleça um modelo operacional com patrocínio executivo, responsável pelo programa, proprietários de controles, operadores, revisores e rotas de escalonamento. Mantenha calendário, registro de decisões, inventário de evidências, registro de remediação e processo de reavaliação acionado por mudanças.

Chapter 02 — Aplicabilidade e limites de entidade/validação

Determine por que o PCI DSS se aplica, quais entidades e ambientes estão no escopo e qual caminho de validação é esperado. Separe requisitos PCI DSS de obrigações contratuais, do adquirente, das bandeiras e de leis jurisdicionais.

Chapter 03 — Dados de conta e limites de proteção

Classifique dados de conta, incluindo PAN e dados sensíveis de autenticação, e defina padrões permitidos de coleta, processamento, transmissão, exibição e armazenamento. Mantenha regras de retenção, descarte, mascaramento, truncamento e proteção criptográfica.

Chapter 04 — Escopo e limites do CDE

Defina o ambiente de dados do portador de cartão e os sistemas conectados ou capazes de afetar sua segurança. Use procedimentos repetíveis considerando redes, identidades, administração, serviços compartilhados, nuvem, ferramentas de segurança e terceiros.

Chapter 05 — Fluxos de dados e segmentação

Mantenha diagramas atuais dos fluxos de pagamento e dados de conta. Quando a segmentação reduzir o escopo, documente objetivo, pontos de controle, dependências administrativas, método de teste e evidência de eficácia contínua.

Chapter 06 — Papéis, validação e garantia

Defina responsabilidades de gestão, operação, garantia interna, QSA/ISA, ASV, adquirente e bandeiras. Diferencie SAQ, ROC e AOC dos requisitos de segurança subjacentes.

Chapter 07 — Abordagens definida, customizada e controles compensatórios

Identifique a abordagem aplicável a cada requisito. Para controles compensatórios, documente restrição, objetivo, risco, desenho, validação, aprovação, vencimento/reavaliação e evidência.

Chapter 08 — Arquitetura de evidência e caminhos de implementação

Use caminhos Essencial, Estruturado e Aprimorado para escalar o rigor operacional sem alterar obrigações. Cada objeto de evidência deve indicar objetivo, escopo, proprietário, procedimento, frequência, artefato, localização, retenção, revisão/teste, resultado, exceção/remediação e gatilho de reavaliação.

Chapter 09 — Controles de segurança de rede

Defina controles de rede ao redor do CDE e ambientes conectados por meio de arquitetura aprovada, padrões de configuração, controle de mudanças, revisão de regras e retenção de evidências.

Chapter 10 — Configurações seguras

Mantenha padrões endurecidos para componentes no escopo e trate desvios por exceções controladas. Preserve baseline, estado, mudanças, revisões e verificação.

Chapter 11 — Proteção de dados de conta armazenados

Minimize armazenamento e retenha dados apenas por necessidades documentadas. Aplique mascaramento, truncamento, criptografia, gestão de chaves e descarte conforme aplicável.

Chapter 12 — Criptografia em transmissão

Proteja dados de conta em redes abertas ou públicas com protocolos e configurações criptográficas atuais e aprovadas. Mantenha inventários de fluxos, configurações e validação periódica.

Chapter 13 — Defesas contra malware

Identifique sistemas sujeitos a risco de malware e implemente prevenção, detecção, monitoramento, atualização e resposta. Documente decisões de aplicabilidade e sua reavaliação periódica.

Chapter 14 — Sistemas e software seguros

Integre prevenção de vulnerabilidades, codificação segura, mudanças, segregação de funções, testes e aprovação de releases ao ciclo de desenvolvimento, incluindo dependências de comércio eletrônico quando aplicável.

Chapter 15 — Gestão de vulnerabilidades

Opere um ciclo de descoberta, avaliação de risco, priorização, proprietário, remediação, exceção, reteste e métricas. Saída de ferramenta é insumo de evidência, não prova de conformidade por si só.

Chapter 16 — Controle de mudanças e garantia de configuração

Exija solicitação, avaliação de impacto, autorização, testes, implementação, rollback e verificação posterior para mudanças materiais. Inclua implicações de escopo PCI.

Chapter 17 — Modelo de controle de acesso

Conceda acesso por necessidade de negócio, menor privilégio, papéis e segregação de funções. Mantenha evidências de entrada, mudança, saída, privilégios e revisões periódicas.

Chapter 18 — Identidade, autenticação e MFA

Mantenha ciclos de identidade, padrões de autenticação, MFA, contas de serviço, segredos e controles privilegiados. Evidencie cadastro, configuração, revisão, revogação e resposta a anomalias.

Chapter 19 — Acesso físico

Controle acesso físico a instalações, sistemas, mídias e áreas relevantes. Mantenha evidências de visitantes, credenciais, mídias, descarte e revisões conforme aplicável.

Chapter 20 — Logs e monitoramento

Defina fontes de logs, coleta, sincronização, retenção, revisão, alertas, escalonamento e localizações de evidência. Demonstre operação e investigação de eventos significativos.

Chapter 21 — Testes de segurança

Mantenha programa de varredura, testes de penetração, validação de segmentação, avaliação sem fio quando aplicável e outros testes exigidos, com escopo, independência, frequência, evidência, remediação e reteste.

Chapter 22 — Varreduras externas e limites ASV

Diferencie varreduras internas de preparação dos resultados oficiais ASV quando aplicável. Ferramentas abertas ou comerciais não substituem validação qualificada.

Chapter 23 — Testes de penetração e validação de segmentação

Defina objetivo, escopo, independência/competência, metodologia, tratamento de resultados, remediação e reteste. Verifique segmentação contra caminhos realistas e dependências administrativas.

Chapter 24 — Prestadores de serviço e evidência de terceiros

Inventarie prestadores que armazenem, processem, transmitam, protejam ou possam afetar dados de conta. Mantenha matrizes de responsabilidade, compromissos, atestações, descrição do serviço, dependências e monitoramento.

Chapter 25 — Resposta a incidentes

Mantenha e teste um plano para eventos de pagamento/dados de conta com papéis, comunicações, preservação de evidência, contenção, recuperação, dependências de notificação e lições aprendidas.

Chapter 26 — Exceções e controles compensatórios

Use processo governado com justificativa, objetivo afetado, avaliação de risco, aprovador, vencimento, evidência, monitoramento e remediação. Não transforme exceções em renúncias silenciosas.

Chapter 27 — Operação do caminho de validação

Prepare o caminho aplicável usando inventário de evidências, matriz de proprietários, rastreamento de problemas e controles de qualidade, separando preparação de SAQ/ROC/AOC da operação real dos controles e do julgamento do avaliador.

Chapter 28 — Conformidade contínua e monitoramento de controles

Programe atividades e evidências ao longo do ano. Monitore saúde dos controles, faltas, evidências obsoletas, exceções, mudanças e envelhecimento de remediações.

Chapter 29 — Remediação e reteste

Para cada achado mantenha proprietário, causa raiz quando viável, plano, prazo, tratamento interino, evidência de conclusão e resultado do reteste. Encerramento exige verificação objetiva.

Chapter 30 — Garantia e reporte à gestão

Reporte escopo, saúde dos controles, achados abertos, exceções, terceiros, atividades futuras e mudanças materiais. Documente aceitação de risco e escalonamento.

Chapter 31 — Progressão de maturidade e capacidade

Evolua da coleta reativa de evidências para garantia repetível, medida e mais automatizada. Maturidade melhora qualidade e tempestividade, mas não substitui requisitos aplicáveis.

Chapter 32 — Cenários de implementação e falhas

Use cenários realistas de escopo, incidentes, varreduras com falha, acessos anômalos, mudanças de fornecedor, migrações para nuvem, comércio eletrônico, falhas de segmentação e lacunas de evidência. Registre lições e melhorias.